

Vendor Risk Assessment Procedure

Northwind Analytics Ltd · NW-SEC-009 · Revision 2 · Classification: Internal

1. Purpose

This procedure describes how Northwind Analytics Ltd assesses and monitors the security risk presented by third-party suppliers. It applies to any supplier that stores, processes, or transmits Company or client information, or that is granted access to a Company network or system. It applies equally to paid and free services, and to trials.

The procedure exists because supplier compromise is now a more common route into an organisation than direct attack. A supplier with weak controls extends its weakness to every customer it serves, and a contract does not mitigate a technical failure.

2. Risk tiering

Every supplier is placed in one of three tiers at onboarding. The tier determines the depth of assessment and the frequency of review. Tier is assigned by the Information Security team, not by the business sponsor, because a sponsor has an obvious interest in the answer being 'low'.

- **Tier 1 — Critical.** Processes Confidential or Restricted information, or has privileged access to production. Full assessment, annual reassessment, right to audit, and a named security contact required.
- **Tier 2 — Significant.** Processes Internal information, or has non-privileged system access. Questionnaire-based assessment and biennial reassessment.
- **Tier 3 — Limited.** No access to Company data or systems. Registration only, with annual confirmation that the scope has not changed.

3. Assessment content

A Tier 1 assessment covers governance, access control, encryption, secure development, vulnerability management, logging and monitoring, incident response, business continuity, sub-processor management, and personnel screening.

Independent assurance is preferred over self-attestation. A current ISO 27001 certificate with a scope statement covering the relevant service, or a SOC 2 Type II report with no material exceptions, satisfies most control areas. A completed questionnaire with no supporting evidence satisfies none of them.

Where a supplier declines to provide evidence on confidentiality grounds, a review under NDA at the supplier's premises is offered. A supplier that declines both is not onboarded at Tier 1, regardless of commercial pressure.

4. Contractual requirements

No Tier 1 or Tier 2 supplier is engaged without the following terms in the executed contract. Legal will not release a contract for signature without them, and a purchase order raised against an unsigned contract is a policy breach.

- A data processing agreement naming the categories of data and the purposes of processing.
- Breach notification to Northwind within 24 hours of the supplier becoming aware.
- A right to audit, exercisable annually with 14 days' notice.
- Prior written approval for any sub-processor, with flow-down of these same terms.
- Defined return and secure destruction of data within 30 days of termination, evidenced by a certificate of destruction.
- Liability provisions that are not capped below the reasonably foreseeable cost of a breach of the data in scope.

5. Ongoing monitoring

Assessment at onboarding establishes a position at a point in time. Suppliers change: they are acquired, they move infrastructure, they add sub-processors, and their staff turn over. Monitoring is therefore continuous rather than periodic.

Tier 1 suppliers are subject to continuous external attack-surface monitoring, immediate review on any publicly disclosed breach affecting them, and a service review at least twice yearly with the business sponsor and Information Security present.

Any supplier that suffers a security incident affecting Northwind data moves to enhanced monitoring for 12 months irrespective of tier, and the business sponsor must produce a written continuation case for the Security Committee.

6. Exit

Every Tier 1 engagement has a documented exit plan before it begins, covering data extraction format, transition period, and the alternative supplier or in-house capability. An exit plan written during an incident is written too late.

On termination, Information Security confirms data destruction, revokes all federated access, and removes the supplier from the network allow-list. The engagement is closed in the supplier register only after all three are evidenced.

All names, figures, and identifiers in this document are synthetic and exist for demonstration purposes only. Northwind Analytics Ltd is a fictional entity.